PORTAIL RIUSC

Réserve d'Intervention d'Urgence en Sécurité Civile du Québec

---

Architecture de sécurité

et mesures de protection des données

Document préparé pour le

Ministère de la Sécurité publique du Québec (MSP)

Version 1.0 - Avril 2026

Classification : Confidentiel

Préparé par :

Dany Chaput, Directeur des opérations en sécurité civile

Association québécoise du bénévolat en recherche et sauvetage (AQBRS)

1. Sommaire exécutif

Le Portail RIUSC est l'application web officielle de la Réserve d'Intervention d'Urgence en Sécurité Civile du Québec. Développé et maintenu par l'AQBRS, il coordonne les disponibilités, certifications, déploiements d'urgence et communications avec les organismes partenaires (SOPFEU, Croix-Rouge, municipalités, MSP). En production depuis 2025, le système gère plus de 900 réservistes actifs déployés lors de sinistres majeurs au Québec.

Ce document présente l'ensemble des mesures de sécurité implémentées pour protéger les renseignements personnels des réservistes et assurer la disponibilité du service en contexte d'urgence. L'architecture a été conçue pour répondre aux exigences de la Loi 25 (Loi modernisant des dispositions législatives en matière de protection des renseignements personnels), aux standards de l'industrie (OWASP Top 10, SOC 2) et aux attentes du Ministère de la Sécurité publique.

Point clé : toutes les données personnelles des réservistes sont hébergées exclusivement au Canada (région ca-central-1 pour la base de données, Beauharnois QC pour l'automatisation).

2. Architecture technique

2.1 Infrastructure d'hébergement

Composante	Détails	Localisation	Données
Base de données	Supabase PostgreSQL (chiffrement AES-256 au repos)	**Canada (ca-central-1)**	**Oui**
Authentification	Supabase Auth (OAuth 2.0, OTP courriel/SMS)	**Canada (ca-central-1)**	**Oui**
Stockage fichiers	Supabase Storage (certificats, documents officiels)	**Canada (ca-central-1)**	**Oui**
Automatisation	n8n self-hosted (VPS OVH, Beauharnois QC)	**Canada (BHS)**	**Oui**
SMS (notifications)	Twilio (transit : téléphone + message pour envoi)	**É.-U. (transit)**	**Transit**
Courriels	Resend (transit : courriel + contenu pour envoi)	**É.-U. (transit)**	**Transit**
Frontend (CDN)	Vercel (serveur edge le plus proche, code seulement)	**CDN mondial**	**Non**
DNS/WAF	Cloudflare (proxy inverse, pare-feu, anti-DDoS)	**CDN mondial**	**Non**

Note importante : Toutes les données personnelles au repos (profils, certificats, disponibilités, journaux) sont stockées exclusivement au Canada dans Supabase (ca-central-1, AWS Montréal) et n8n (OVH Beauharnois). Twilio et Resend sont utilisés uniquement pour l'envoi de notifications (SMS et courriels). Les données y transitent de façon éphémère pour l'acheminement du message, sans stockage permanent. Ces deux fournisseurs sont certifiés SOC 2 Type II et les communications sont chiffrées en transit (TLS).

2.2 Flux de données sécurisé

Le parcours d'une requête utilisateur suit ce cheminement sécurisé :

- L'utilisateur accède à portail.riusc.ca via HTTPS (TLS 1.2+)
- Cloudflare intercepte la requête : inspection WAF, vérification anti-bot, protection DDoS
- La requête est transmise à Vercel (frontend) qui sert l'interface
- Les appels API du navigateur vont directement à Supabase (ca-central-1) via connexion chiffrée
- Les réponses sont retournées au navigateur via le même chemin sécurisé
- Les SMS/courriels d'urgence sont orchestrés par n8n (Beauharnois) et acheminés via Twilio (SMS) et Resend (courriels). Ces services reçoivent les coordonnées du destinataire et le contenu du message de façon éphémère pour l'envoi, sans stockage permanent des données personnelles.

3. Localisation des données et souveraineté

La protection des renseignements personnels des réservistes est au cœur de l'architecture du Portail RIUSC. Toutes les données personnelles sont hébergées au Canada, conformément aux meilleures pratiques et aux attentes de la Loi 25.

3.1 Données personnelles stockées au Canada

Type de données	Service	Région
Profils réservistes (nom, courriel, téléphone, adresse, compétences)	Supabase PostgreSQL	ca-central-1 (AWS Montréal)
Certificats et documents officiels	Supabase Storage	ca-central-1 (AWS Montréal)
Identifiants d'authentification	Supabase Auth	ca-central-1 (AWS Montréal)
Journaux d'audit et de connexion	Supabase PostgreSQL	ca-central-1 (AWS Montréal)
Disponibilités et déploiements	Supabase PostgreSQL	ca-central-1 (AWS Montréal)
Workflows SMS/courriel	n8n (VPS OVH self-hosted)	Beauharnois QC, Canada

3.2 Services sans données personnelles

Les services suivants ne contiennent aucune donnée personnelle identifiable :

- **Vercel (CDN) :** héberge uniquement le code source de l'application (HTML, JavaScript, CSS). Aucune donnée personnelle n'est stockée sur Vercel. Les données transitent du navigateur directement vers Supabase au Canada.

- **Cloudflare (WAF) :** agit comme proxy inverse et pare-feu. Les requêtes sont inspectées en temps réel pour bloquer les attaques, mais aucune donnée personnelle n'est conservée. Les journaux de trafic sont anonymisés.

3.3 Certifications des fournisseurs

Fournisseur	Certifications	Siège / Région
Supabase (AWS)	SOC 2 Type II, ISO 27001, HIPAA eligible	Canada (ca-central-1)
OVH	SOC 1/2 Type II, ISO 27001, HDS, SecNumCloud	Canada (Beauharnois QC)
Vercel	SOC 2 Type II, ISO 27001	CDN mondial
Cloudflare	SOC 2 Type II, ISO 27001, PCI DSS	CDN mondial
Twilio	SOC 2 Type II, ISO 27001, HIPAA	É.-U. (transit SMS)
Resend	SOC 2 Type II	É.-U. (transit courriel)

4. Couche de protection réseau (WAF / Pare-feu)

Le portail est protégé par Cloudflare, un service de sécurité de niveau entreprise utilisé par plus de 20% des sites web mondiaux, incluant des organisations gouvernementales. Cloudflare fournit des fonctionnalités équivalentes et supérieures à un pare-feu traditionnel.

4.1 Pare-feu applicatif web (WAF)

Le WAF Cloudflare inspecte chaque requête HTTP/HTTPS avant qu'elle n'atteigne l'application :

- **Règles gérées (Managed Rules) :** protection automatique contre les 10 principales vulnérabilités OWASP (injections SQL, XSS, CSRF, traversées de répertoires, etc.)
- **Mises à jour continues :** les signatures de menaces sont mises à jour en continu par l'équipe de sécurité Cloudflare, sans intervention manuelle
- **Bot Fight Mode :** détection et blocage automatique des robots malveillants (scrapers, credential stuffing, etc.)
- **Géoblocage optionnel :** possibilité de restreindre l'accès par pays si nécessaire

4.2 Protection contre les attaques par déni de service (DDoS)

- Mitigation automatique des attaques volumétriques (couches 3, 4 et 7 du modèle OSI)
- Capacité réseau de 280+ Tbps pour absorber les attaques les plus importantes
- Protection always-on sans intervention manuelle ni dégradation de service
- SLA de disponibilité de 100% sur la mitigation DDoS

4.3 Chiffrement SSL/TLS

Le mode SSL/TLS est configuré en **Full (strict)**, ce qui signifie :

- Chiffrement de bout en bout entre le navigateur, Cloudflare et le serveur d'origine
- Vérification du certificat SSL du serveur d'origine (pas seulement le chiffrement, mais aussi l'authenticité)
- Protection contre les attaques de type man-in-the-middle (MITM)
- TLS 1.2 minimum imposé, TLS 1.3 supporté et favorisé

4.4 En-têtes de sécurité HTTP

L'application définit les en-têtes de sécurité suivants sur toutes les réponses HTTP, conformément aux recommandations OWASP :

En-tête	Protection apportée
Content-Security-Policy (CSP)	Restreint les sources autorisées de scripts, styles, images et connexions. Empêche l'exécution de code malveillant injecté.
Strict-Transport-Security (HSTS)	Force le navigateur à utiliser HTTPS pendant 1 an, incluant tous les sous-domaines. Enregistré dans la liste preload des navigateurs.
X-Frame-Options: DENY	Empêche l'intégration du portail dans un iframe externe (protection contre le clickjacking).
X-Content-Type-Options: nosniff	Empêche le navigateur de deviner le type MIME (protection contre les attaques par confusion de type).
Referrer-Policy	Contrôle les informations transmises dans les en-têtes Referer lors de la navigation vers des sites externes.
Permissions-Policy	Désactive les API navigateur non nécessaires (caméra, microphone). Seule la géolocalisation est autorisée (pour le ciblage des réservistes proches d'un sinistre).

4.5 Limitation de débit (Rate Limiting)

Un système de limitation de débit par adresse IP est implémenté dans le middleware de l'application pour prévenir les attaques par force brute et les abus :

Route protégée	Raison	Limite	Fenêtre
/login	Anti brute-force connexion	10 requêtes	60 secondes
/api/admin/*	Protection API administration	60 requêtes	60 secondes
/api/impersonate	Emprunt d'identité admin	5 requêtes	60 secondes
/api/webhooks/*	Protection webhooks entrants	30 requêtes	60 secondes
/inscription	Anti-spam inscriptions	10 requêtes	60 secondes

En cas de dépassement, l'utilisateur reçoit une réponse HTTP 429 (Too Many Requests) avec un en-tête Retry-After.

5. Authentification et autorisation

5.1 Authentification sans mot de passe (Passwordless)

Le portail utilise exclusivement l'authentification sans mot de passe, éliminant ainsi la catégorie la plus exploitée de vulnérabilités (compromission de mots de passe, réutilisation, hameçonnage) :

- **OTP par courriel :** un lien magique à usage unique est envoyé au courriel du réserviste. Le lien expire après 60 minutes.
- **OTP par SMS :** un code à 6 chiffres est envoyé par SMS au téléphone du réserviste via Twilio. Adapté aux réservistes sur le terrain sans accès courriel.
- **Sessions JWT :** les sessions sont gérées par des jetons JWT avec expiration automatique. Les jetons sont rafraîchis de façon transparente.
- **Aucun mot de passe stocké :** il n'existe aucune table de mots de passe dans le système, éliminant tout risque de fuite de credentials.

5.2 Modèle de rôles et principe du moindre privilège

L'accès aux données est contrôlé par un système de 7 rôles hiérarchiques. Chaque rôle n'a accès qu'aux fonctionnalités strictement nécessaires à ses responsabilités :

Rôle	Permissions	Population
superadmin	Accès complet : configuration, gestion utilisateurs, impersonation, audit	2 comptes (principal + secours)
admin	Gestion sinistres, déploiements, ciblage, validation certificats	2-3 personnes
coordonnateur	Opérations terrain, gestion réservistes, ciblage	3-5 personnes
adjoint	Consultation réservistes, export CSV	5-10 personnes
réserviste	Son profil uniquement, disponibilités, formations	900+ personnes
partenaire_lect	Lecture seule sans données nominatives (Loi 25)	Responsables partenaires
partenaire	Lecture seule : demandes et déploiements de son organisme	Agents partenaires

5.3 Impersonation sécurisée

Les administrateurs peuvent emprunter temporairement l'identité d'un réserviste pour le support technique. Cette fonctionnalité est protégée par : vérification du rôle superadmin/admin, journalisation de chaque impersonation, bandeau visuel permanent indiquant que le mode est actif, et limitation à 5 requêtes par minute.

5.4 Authentification multifacteur (2FA) sur tous les services

L'authentification à deux facteurs (2FA) est activée sur l'ensemble des services tiers utilisés par le Portail RIUSC. Cela garantit qu'un mot de passe compromis ne suffit pas à accéder aux systèmes d'administration :

Service	Rôle dans l'infrastructure	2FA
GitHub	Dépôt du code source, contrôle de version	**Activé**
Vercel	Déploiement frontend, variables d'environnement	**Activé**
Cloudflare	DNS, WAF, protection DDoS, SSL/TLS	**Activé**
Supabase	Base de données, authentification, stockage	**Activé**
Resend	Envoi de courriels transactionnels	**Activé**
Twilio	Envoi de SMS de notification	**Activé**

Chaque service dispose d'un compte de secours (portail@aqbrs.ca) également protégé par 2FA, assurant la continuité d'accès en cas d'indisponibilité du compte principal.

6. Sécurité des données

6.1 Row Level Security (RLS) - Isolation des données

L'ensemble des 33 tables de la base de données sont protégées par des politiques Row Level Security (RLS) au niveau PostgreSQL. Ce mécanisme garantit que même en cas de faille applicative, un utilisateur ne peut physiquement accéder qu'à ses propres données au niveau de la base de données.

- **33/33 tables protégées** par des politiques RLS
- **Audit complet réalisé en avril 2026 :** correction d'une faille permettant la lecture anonyme d'une table, nettoyage de 10 politiques redondantes
- **Principe :** un réserviste voit ses propres données uniquement. Un admin voit tout. La clé service_role contourne le RLS pour les opérations automatisées (n8n) mais n'est jamais exposée au client.

6.2 Chiffrement multicouche

Couche	Méthode	Standard
En transit (réseau)	TLS 1.2+ sur toutes les communications	Forcé via HSTS preload
Au repos (base de données)	AES-256 (Supabase/AWS)	Standard gouvernemental
Au repos (fichiers)	AES-256 (Supabase Storage)	Certificats et documents
Sauvegardes	Chiffrées automatiquement (Supabase)	Backup quotidien
Poste de travail	BitLocker (XTS-AES 256 bits, chiffrement intégral)	Standard gouvernemental

Le poste de travail administratif est protégé par le chiffrement intégral du disque via BitLocker (XTS-AES 256 bits, mode de chiffrement intégral). En cas de perte ou de vol du poste, les données, le dépôt de code source et les fichiers de configuration locaux restent inaccessibles sans la clé de récupération.

6.3 Gestion des secrets et clés API

Une gestion rigoureuse des secrets est appliquée sur l'ensemble de la chaîne de développement et de déploiement :

- **Variables d'environnement sécurisées :** toutes les clés API sont stockées dans des variables d'environnement (Vercel pour la production, .env.local pour le développement). Les variables sensibles sont marquées comme "Sensitive" dans Vercel, rendant leur valeur invisible même aux membres de l'équipe.
- **Zéro clé dans le code source :** un audit complet en avril 2026 a identifié et retiré 13 fichiers contenant des clés exposées dans l'historique Git. Le dépôt est désormais propre.
- **Rotation des clés (avril 2026) :** migration complète des clés Supabase de l'ancien format JWT vers le nouveau format sécurisé (sb_publishable_ / sb_secret_). Les anciennes clés JWT ont été désactivées et sont inutilisables.
- **GitHub Secret Scanning :** analyse automatique de chaque commit pour détecter les clés API, tokens et secrets accidentellement commis. Alertes immédiates en cas de détection.
- **GitHub Push Protection :** bloque proactivement tout push contenant un secret détecté avant qu'il n'atteigne le dépôt. Première ligne de défense contre les fuites accidentelles.
- **Séparation des clés :** stricte séparation entre la clé publique (publishable, permissions limitées par RLS) et la clé privée (secret, utilisée uniquement côté serveur et dans n8n).

7. Conformité à la Loi 25

La Loi 25 (Loi modernisant des dispositions législatives en matière de protection des renseignements personnels) impose des obligations en matière de collecte, utilisation, communication et hébergement des renseignements personnels. Voici comment le Portail RIUSC répond à chacune de ces exigences :

Exigence Loi 25	Mesure implémentée	Statut
Hébergement au Canada	Données au repos en ca-central-1 (AWS Montréal) et OVH Beauharnois. Twilio/Resend : transit éphémère pour envoi SMS/courriels, certifiés SOC 2.	**Conforme**
Minimisation des données	Les partenaires externes (partenaire_lect) n'ont accès à aucune donnée nominative (noms, courriels, téléphones masqués).	**Conforme**
Consentement	Inscription volontaire des réservistes avec acceptation des conditions d'utilisation.	**Conforme**
Droit d'accès et rectification	Chaque réserviste peut consulter, modifier et mettre à jour l'ensemble de ses données personnelles via son profil (100+ champs).	**Conforme**
Traçabilité	5 tables d'audit : connexions, visites de pages, événements d'authentification, actions IA, inscriptions camps.	**Conforme**
Mesures de sécurité	WAF, DDoS, RLS 33/33 tables, chiffrement AES-256, rate limiting, CSP, HSTS, 2FA sur 6/6 services.	**Conforme**
Notification d'incident	Journalisation complète permettant la détection et l'investigation d'incidents.	**Conforme**
Conservation limitée	Certificats avec dates d'expiration. Possibilité de purge des comptes inactifs.	**Conforme**

8. Audit et journalisation

Le système maintient une trace complète de toutes les activités pour permettre l'investigation d'incidents et répondre aux obligations de traçabilité :

Table d'audit	Données enregistrées	Rétention
audit_connexions	Chaque connexion (user_id, date, méthode OTP)	Indéfinie
audit_pages	Chaque visite de page (user_id, page, timestamp)	Indéfinie
auth_logs	Tentatives d'authentification (succès et échecs)	Indéfinie
agent_logs	Actions IA (suggestions de rotation de déploiement)	Indéfinie
inscriptions_camps_logs	Inscriptions, annulations, modifications aux camps	Indéfinie

9. Disponibilité et continuité de service

En contexte de sécurité civile, la disponibilité du portail est critique lors de sinistres. L'architecture est conçue pour maximiser la disponibilité :

- **Vercel :** CDN mondial avec auto-scaling. Le frontend se déploie sur des dizaines de points de présence. SLA 99.99%.
- **Supabase :** base de données PostgreSQL gérée avec sauvegardes automatiques quotidiennes et restauration point-in-time.
- **Cloudflare :** protection DDoS always-on. Même sous attaque, le service reste disponible.
- **n8n (SMS/courriels) :** VPS OVH dédié avec monitoring. En cas de panne n8n, le portail reste fonctionnel (seuls les envois SMS/courriels sont retardés).
- **Mode maintenance :** activation instantanée via variable d'environnement pour les opérations planifiées.
- **Compte superadmin de secours :** un compte d'urgence (portail@aqbrs.ca) avec le rôle superadmin est configuré pour assurer l'accès au portail même en cas d'indisponibilité du compte administrateur principal.

10. Tableau récapitulatif des mesures de sécurité

Mesure	Implémentation	Norme	Statut
Pare-feu applicatif (WAF)	Cloudflare Managed Rules	OWASP Top 10	**Actif**
Protection DDoS	Cloudflare (280+ Tbps)	Couches 3/4/7	**Actif**
Bot Fight Mode	Cloudflare	Anti-scraping	**Actif**
SSL/TLS Full (strict)	Cloudflare + certificat origine	Anti-MITM	**Actif**
Chiffrement en transit	TLS 1.2+ / HSTS preload	NIST	**Actif**
Chiffrement au repos	AES-256	NIST / FIPS 197	**Actif**
En-têtes de sécurité	CSP, HSTS, X-Frame, etc.	OWASP	**Actif**
Rate Limiting	Middleware par IP	Anti brute-force	**Actif**
Row Level Security	33/33 tables PostgreSQL	Moindre privilège	**Actif**
Auth sans mot de passe	OTP courriel/SMS	Zero password	**Actif**
Contrôle d'accès	7 rôles granulaires	RBAC	**Actif**
2FA services tiers	6/6 services protégés	MFA	**Actif**
Rotation des clés	Migration sb_publishable_/sb_secret_	Bonne pratique	**Actif**
Secret Scanning	GitHub analyse chaque commit	Prévention fuites	**Actif**
Push Protection	GitHub bloque les secrets	Prévention fuites	**Actif**
Dépendances automatisées	Dependabot (GitHub)	Supply chain	**Actif**
Variables sensibles	Vercel Sensitive Env Vars	Moindre privilège	**Actif**
Journalisation	5 tables d'audit	Traçabilité	**Actif**
Données au Canada	Supabase ca-central-1 + OVH BHS	Loi 25	**Actif**
Compte de secours	superadmin portail@aqbrs.ca	Continuité	**Actif**
Chiffrement poste admin	BitLocker XTS-AES 256 bits (intégral)	Protection physique	**Actif**
Conformité Loi 25	9/9 exigences couvertes	Loi 25 QC	**Conforme**

11. Gouvernance et amélioration continue

La sécurité est un processus continu. Voici les mesures de gouvernance en place et planifiées :

- **Audits réguliers :** audit RLS complet réalisé en avril 2026, incluant la correction de vulnérabilités et le nettoyage des politiques redondantes. Prochain audit prévu à l'automne 2026.
- **Mises à jour automatisées des dépendances :** Dependabot (GitHub) surveille en permanence les dépendances du projet et crée automatiquement des demandes de mise à jour lorsqu'une vulnérabilité est découverte ou qu'une nouvelle version est disponible. Chaque mise à jour est validée par un build automatisé avant intégration.
- **Déploiement continu :** chaque modification de code est déployée via Vercel avec build automatisé. Les erreurs de build bloquent le déploiement.
- **Monitoring :** surveillance des requêtes (42 000+ requêtes/24h en production), alertes automatiques en cas d'anomalie.
- **Plan de tests :** mise en place de tests automatisés sur les routes API critiques (en cours de déploiement).
- **Évaluation EFVP :** évaluation des facteurs relatifs à la vie privée documentée pour tous les sous-traitants technologiques.
- **Protection de la chaîne d'approvisionnement :** GitHub Secret Scanning, Push Protection et Dependabot forment un triplé de protection qui sécurise le code source, les secrets et les dépendances de façon proactive et automatisée.

12. Contact

Pour toute question relative à la sécurité du Portail RIUSC ou pour demander des précisions sur les mesures décrites dans ce document :

- **Responsable :** Dany Chaput, Directeur des opérations en sécurité civile
- **Courriel :** dany.chaput@aqbrs.ca
- **Organisation :** AQBRS (Association québécoise du bénévolat en recherche et sauvetage)
- **Portail :** https://portail.riusc.ca